

Cirque Corporation

ISMS Scope Definition Procedure

Document ID: IS-CIRQ-PR-001-G

Category: Base Policy & ISMS Manual

Division: Procedure

Type: Global

Version: 1.1

Effective Date: July 2025

Review Date: July 2026

Approved By: \[IT Department Head / Information Security

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the process for establishing and maintaining the scope of Cirque's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 4.3. A clearly defined scope ensures that all relevant information assets, processes, and locations are included, and that the ISMS effectively supports Cirque's business objectives.

****2. Scope****

2. Scope

This procedure applies to all activities involved in defining, documenting, and reviewing the ISMS scope, including relevant internal and external issues, interested parties' requirements, and interfaces with Cirque's manufacturing and business functions.

****3. Responsibilities****

3. Responsibilities

- **Executive Committee:** Provides ultimate approval for the ISMS scope.
- **IT Department / Information Security Manager (ISM):** Responsible for leading the scope definition process, documenting the scope, and ensuring its review and communication. Also responsible for maintaining the ISMS Scope Document.
- **Department Heads/Process Owners:** Provide input regarding their respective areas, information assets, and processes that fall within or interface with the ISMS scope.

4. Procedure

4.1. Identify Internal and External Issues (ISO 27001 Clause 4.1) a. The IT Department / ISM will identify and analyze internal and external issues relevant to Cirquel's purpose and its ability to achieve the intended outcomes of the ISMS. This includes:

- Internal Issues:** Organizational culture, capabilities (e.g., resources, knowledge), governance structure, information technology infrastructure, manufacturing processes, operational technology (OT) systems (even if not currently in scope, their potential future inclusion is considered), and proprietary information like designs and customer data.
- External Issues:** Legal and regulatory requirements (e.g., data privacy laws like CCPA, APPI, PIPL, state data breach notification laws), technological advancements, competitive landscape, market conditions, and societal expectations.

b. The analysis of these issues will inform the boundaries and applicability of the ISMS.

4.2. Identify Interested Parties and Their Requirements (ISO 27001 Clause 4.2) a. The IT Department / ISM will identify internal and external interested parties relevant to the ISMS. This includes, but is

not limited to: * **Internal:** Employees, management, the Executive Committee, internal audit. * **External:** Customers (including those in Japan, Taiwan, and China), suppliers, regulators, investors, partners, local communities, law enforcement, and auditors. b. The IT Department / ISM will determine the information security requirements of these interested parties that are relevant to the ISMS. This may involve reviewing contracts, regulations, and industry best practices. c. Document identified interested parties and their requirements in IS-CIRQ-D-002-G: Interested Parties and Their Requirements Register.

4.3. Determine ISMS Boundaries and Applicability (ISO 27001 Clause 4.3)

a. Based on the analysis from sections 4.1 and 4.2, the IT Department / ISM, in consultation with relevant department heads, will define the physical and logical boundaries of the ISMS. This includes:

- * **Organizational Units:** Which departments, teams, or business functions are included (e.g., specific manufacturing functions, R&D, Sales, IT, Finance, HR).
- * **Physical Locations:** Which buildings, sites, or geographic regions are covered. Initially, this includes:
 - * Main Headquarters and Production Facility, Sandy, Utah, USA.
 - * Sales and Operations Office, Taipei, Taiwan.
 - * Business operations and relationships with entities in Japan and China.
- * **Information Assets:** Which types of information (e.g., customer data, intellectual property, financial data, employee data, manufacturing designs, raw material specifications) and associated IT assets (e.g., servers, workstations, network devices, business applications, cloud services) are within scope.
- * **Technologies:** Which IT systems, networks, and applications are included. While no specific OT assets are currently integrated into the ISMS scope, the ISMS is designed to be extensible to include them should they become information-security-critical.
- * **Processes:** Which business and manufacturing processes generating, processing, or storing information are covered by the ISMS (e.g.,

customer order processing, product design, financial reporting, employee onboarding, IT support). b. Any exclusions from the scope must be justified and documented, ensuring they do not compromise the confidentiality, integrity, or availability of information critical to Cirque's core business functions. c. The ISMS scope must be clearly documented in the IS-CIRQ-D-001-G: ISMS Scope Document.

****4.4. ISMS Scope Review and Approval**** a. The proposed ISMS scope documented in IS-CIRQ-D-001-G will be reviewed by the IT Department / ISM and relevant stakeholders. b. The ISMS scope must be formally approved by the ****Executive Committee****. c. Any changes to the ISMS scope must follow this procedure and be formally re-approved by the Executive Committee.

****5. Related Documents****

5. Related Documents

- IS-CIRQ-D-001-G: ISMS Scope Document
- IS-CIRQ-D-002-G: Interested Parties and Their Requirements Register
- IS-CIRQ-D-003-G: Legal, Regulatory, and Contractual Requirements Register